

 **Problema a Solucionar:** Las brechas de seguridad técnicas (vulnerabilidades) no significan nada para la mesa directiva si no se traducen en métricas de negocio. Las organizaciones necesitan entender su exposición real mapeando los hallazgos técnicos contra el **Apetito de Riesgo** definido por la empresa, es decir, que tanto riesgo están dispuestos a aceptar para lograr los objetivos del negocio. Este análisis permite además identificar escenarios que no suelen ser detectados a simple vista, como el ataque encadenado (Kill Chains) que amenazan la continuidad operativa ya que pueden afectar más de un activo, asegurar el cumplimiento normativo (ISO 27001) o proteger la reputación comercial.

 **Metodología Aplicada:** Gobierno, Riesgo y Cumplimiento (GRC) alineado a los estándares ISO 27005 y NIST SP 800-30 para el análisis de riesgos.

1. Definición e implementación del Contexto y Risk Appetite: Establecimiento de niveles de riesgo asumibles (Umbral de Tolerancia) alineados a la operación del negocio y sus objetivos.
2. Modelado de Amenazas Avanzado: Simulación de escenarios de abuso estructural basados en taxonomías internacionales reconocidas como CWE (Deficiencias de software) y CAPEC (Mecanismos de ataque) para facilitar su comprensión y remediación.
3. Priorización Cuantitativa del Riesgo: Cálculo de matrices de Probabilidad vs. Impacto para alejar las decisiones del criterio subjetivo.
4. Diseño de un Plan de Tratamiento y KPIs: Creación de estrategias formales (Mitigar, Evitar, Aceptar, Transferir) con asignación de responsabilidades, plazos realistas y métricas de cumplimiento medibles.

 **Resultados obtenidos (Caso de Estudio Muestra):** En el ecosistema evaluado (infraestructura corporativa perimetral distribuida con protección WAF) presenta los siguientes escenarios críticos identificados.

Elusión del perímetro WAF para obtención de información técnica que permite diseñar ataques dirigidos a plataformas de correo, servicios de administración remota y explotación encadenada de componentes *legacy* en estado Fin de Vida (EOL).

Métricas de control propuestas: KPIs específicos enfocados en la reducción del 80% de la superficie de puertos expuestos y el forzado del 100% del tráfico externo a través de la inspección del WAF.

 **Marcos de Trabajo y Referencias:** ISO/IEC 27005 (Gestión de riesgos de seguridad de la Información). Mitre CAPEC (Common Attack Pattern Enumeration and Classification) para modelado de amenazas. Mitre CWE (Common Weakness Enumeration) para identificar debilidades y problemas de configuración. Matriz de probabilidad e impacto cuantitativa para priorizar inversión y tiempos de remediación.

Lecciones aprendidas: En ocasiones la persona responsable de las decisiones no cuenta con los conocimientos técnicos necesarios para comprender completamente las repercusiones de alguna vulnerabilidad o condición de riesgo específica. Traducir dichos hallazgos a lenguaje de negocios ayuda enormemente a implementar una correcta administración de recursos, asignación de prioridades e inversión en actualizar tecnologías, reduciendo la incertidumbre durante la toma de decisiones.

Valor para la organización: Traducir información técnica en datos relevantes para el negocio convierte un simple reporte técnico en una herramienta eficaz para la toma de decisiones, facilita la comunicación entre las distintas áreas de la organización y permite asignar prioridades con la seguridad de que son decisiones bien informadas.